

Risk ID	Risk Domain	Business Process	Asset/System	Risk Statement	Threat/Cause	Likelihood	Impact	Inherent Risk Score	Risk Rating	Existing Controls	Control Gap	Recommendation	Risk Owner
R-001	Identity & Access Management	Customer Login & Authentication	Authentication & MFA Service / Customer Brokerage Account	Unauthorized users may gain access to customer brokerage accounts if customer credentials or authentication mechanisms are compromised, potentially resulting in fraudulent trades, unauthorized withdrawals, or exposure of sensitive customer information.	Phishing, credential theft, credential stuffing, compromised passwords	4	5	20	Critical	MFA for customer authentication; failed-login lockout; suspicious-login monitoring	Step-up authentication is not consistently required for high-risk account changes such as adding a new bank account or modifying customer contact information.	Require step-up MFA or additional identity verification for high-risk account changes and unusual withdrawal activity.	Information Security / Brokerage Operations
R-002	Transaction & Fraud Controls	Bank Account Changes & Withdrawals	Brokerage Core Platform / Bank-ACH Processor / Customer Brokerage Account	Unauthorized users may add or modify linked bank accounts and initiate fraudulent withdrawals, potentially resulting in customer financial losses, reimbursement costs, regulatory exposure, and reputational damage.	Account takeover, compromised credentials, social engineering, unauthorized bank-account changes	4	5	20	Critical	Customer notifications for bank-account changes; withdrawal transaction monitoring; withdrawal limits; bank-account ownership verification	Step-up authentication is not required before adding a new external bank account, and withdrawals may be initiated shortly after the account change.	Require step-up MFA and bank-account ownership verification for new external accounts and implement additional review or temporary withdrawal restrictions following high-risk bank-account changes.	Fraud Risk / Brokerage Operations / Information Security
R-003	Identity & Access Management	Employee & Privileged Access Management	Employee Admin Portal / Brokerage Core Platform / Customer Account Database	Employees or administrators may retain excessive or inappropriate access to customer accounts and critical brokerage systems, potentially enabling unauthorized changes, exposure of sensitive information, fraud, or circumvention of internal controls.	Excessive permissions, stale accounts, improper role changes, delayed account termination	3	5	15	High	Role-based access control (RBAC); MFA for employee access; manager approval for privileged access; termination-based account deactivation; privileged activity logging	Periodic access reviews are not performed consistently, increasing the risk that employees who change roles or leave the organization may retain unnecessary or privileged access.	Perform quarterly user-access reviews, automate account deactivation for terminated employees, and require documented approval for new or elevated privileged access.	Identity & Access Management / IT Operations
R-004	Logging & Monitoring	Security Monitoring & Incident Detection	Security Logging & Monitoring / Authentication & MFA / Employee Admin Portal / Brokerage Core Platform	Security-relevant activity may not be logged, retained, or reviewed adequately, potentially delaying detection of account compromise, employee misuse, fraudulent activity, or other security incidents.	Incomplete logging, inadequate alerting, insufficient log review, improper log retention	3	4	12	High	Centralized security logging; automated alerts for suspicious activity; authentication logs; administrative activity logs; defined log-retention requirements	Logging coverage is inconsistent across critical systems, and alerts for high-risk administrative and customer-account activity are not reviewed within a defined timeframe.	Ensure critical systems send security and administrative activity logs to centralized monitoring, define alert thresholds for high-risk events, and establish documented review and escalation timeframes.	Information Security / Security Operations
R-005	Trade Processing & Operations	Trade Order Processing & Execution	Brokerage Core Platform / Order Management System / Trade Execution Provider	Trade orders may be duplicated, incorrectly processed, rejected without proper handling, or inaccurately recorded due to system, interface, or processing failures, potentially resulting in incorrect customer positions, financial losses, customer complaints, or operational and regulatory exposure.	System errors, interface failures, duplicate order submission, processing errors, inaccurate execution data	3	5	15	High	Pre-trade order validation; duplicate-order prevention; execution confirmations; order-status monitoring; daily trade reconciliation; exception reporting	Trade execution records are not reconciled to internal order records in near real time, increasing the risk that failed, duplicated, or incorrectly recorded trades may not be identified promptly.	Implement automated reconciliation between the Order Management System and Trade Execution Provider, generate alerts for unmatched or duplicate transactions, and establish documented procedures for timely investigation and resolution of trade exceptions.	Trading Operations / Brokerage Operations / Technology
R-006	Data Protection & Privacy	Customer Data Storage & Access	Customer Account Database / Employee Admin Portal / Brokerage Core Platform	Sensitive customer information may be exposed, accessed by unauthorized individuals, or improperly disclosed due to inadequate data-protection controls, potentially resulting in identity theft, financial fraud, regulatory exposure, customer harm, and reputational damage.	Unauthorized access, excessive employee permissions, database compromise, improper data handling, unencrypted or insufficiently protected sensitive information	3	5	15	High	Encryption at rest and in transit; role-based access controls; sensitive-data masking; database access logging; MFA for employee access	Customer-support personnel can view certain sensitive customer information in full even when the information is not required to perform routine support responsibilities.	Mask sensitive customer information by default, restrict access to full data based on documented business need, and log and periodically review instances where employees access unmasked sensitive information.	Information Security / Data Protection / Brokerage Operations
R-007	Change Management	Application & Production Change Management	Web / Mobile Application / Order Management System	Unauthorized, inadequately tested, or improperly implemented system changes may disrupt critical brokerage operations, introduce security vulnerabilities, or result in inaccurate customer and transaction data.	Insufficient testing, unauthorized changes, inadequate approvals, configuration errors, failed deployments	3	5	15	High	Documented change requests; management approval; pre-production testing; separation of development and production access; rollback procedures; emergency change process	Emergency production changes may be implemented before independent approval and are not consistently subjected to documented post-implementation review.	Require documented post-implementation review and independent approval for emergency changes, including validation of testing results, business impact, and rollback readiness.	Technology / Application Development / Change Management
R-008	Third-Party Risk	Third-Party Service Management	Cloud Service Provider / Bank-ACH Processor / Identity Verification Provider / Trade Execution Provider	Critical third-party service providers may experience security incidents, operational failures, or service outages that disrupt A.U. Securities' brokerage operations, expose sensitive information, or affect the processing of customer transactions.	Vendor security breach, service outage, inadequate vendor controls, concentration risk, weak third-party oversight	3	5	15	High	Pre-contract vendor due diligence; contractual security requirements; service-level agreements; periodic vendor assessments; SOC report review; incident-notification requirements	Critical vendors are not consistently classified by risk level, and periodic reassessments are not completed for all providers that support sensitive data or critical brokerage operations.	Implement a formal third-party risk-tiering process, require periodic reassessments of critical vendors, document review of independent control reports, and establish remediation and escalation procedures for identified vendor-control weaknesses.	Third-Party Risk / Technology / Procurement
R-009	Business Continuity & Resilience	Business Continuity & Disaster Recovery	Cloud / Infrastructure / Brokerage Core Platform / Customer Account Database / Backup & Disaster Recovery	Critical brokerage systems may become unavailable or customer and transaction data may be unrecoverable following a system failure, cloud-service outage, cyber incident, or other disruption, potentially preventing customers from accessing accounts or completing brokerage transactions.	Cloud outage, hardware or system failure, corrupted data, inadequate backups, unsuccessful disaster recovery	3	5	15	High	Automated backups; redundant infrastructure; disaster-recovery environment; system availability monitoring; documented business continuity and disaster-recovery plans	Disaster-recovery testing is performed inconsistently and does not fully validate the recovery of critical brokerage processes, customer data, and dependencies on third-party service providers.	Establish defined recovery time and recovery point objectives for critical systems, perform periodic end-to-end disaster-recovery testing, validate restoration of customer and transaction data, and include critical third-party dependencies in recovery exercises.	Business Continuity / Technology / Brokerage Operations
R-010	Trade Processing & Operations	Transaction Reconciliation & Account Records	Brokerage Core Platform / Customer Account Database / Order Management System / Bank-ACH Processor	Differences between internal brokerage records and external transaction records may not be identified or resolved promptly, potentially resulting in inaccurate customer balances, incorrect positions, transaction errors, or financial reporting issues.	Interface errors, delayed transaction updates, failed data transfers, inaccurate records, unreconciled exceptions	2	4	8	Moderate	Daily transaction reconciliation; automated exception reports; trade execution confirmations; bank transaction matching; supervisory review of unresolved exceptions	Certain reconciliation customers may remain unresolved beyond established review periods, and escalation requirements for aging exceptions are not consistently documented.	Establish documented escalation thresholds for unresolved reconciliation exceptions, track exception aging, and require supervisory review of material or overdue differences.	Brokerage Operations / Finance Operations

R-011	Vulnerability & Patch Management	Vulnerability Identification & Remediation	Web / Mobile Application / Cloud Infrastructure / Brokerage Core Platform	Security vulnerabilities in critical brokerage systems may not be identified or remediated within appropriate timeframes, increasing the risk of unauthorized access, system compromise, data exposure, or disruption of brokerage operations.	Unpatched software, outdated components, delayed remediation, configuration weaknesses, inadequate vulnerability scanning	3	4	12	High	Automated vulnerability scanning; security patching procedures; remediation deadlines based on severity; configuration reviews; vulnerability tracking	Establish formal escalation procedures for overdue high-risk vulnerabilities, require documented remediation or approved risk acceptance, and provide management with periodic reporting on outstanding vulnerabilities.	Information Security / Technology Operations	Information Security / Technology Operations
R-012	Market Data & Customer Experience	Customer Market Data Display	Web / Mobile Application / Market Data Provider	Temporary delays or inaccuracies in customer-facing market data may cause customers to view outdated quotes or pricing information, potentially creating confusion, customer complaints, or minor service issues.	Delayed market-data feed, temporary API failure, stale cached pricing, display error	2	2	4	Low	Redundant market-data feeds; timestamped quotes; automated feed-health monitoring; stale-data alerts	Customer-facing applications do not consistently display a clear warning when market-data updates are temporarily delayed.	Display visible stale-data indicators when market-data feeds are delayed and automatically alert technology operations when quote updates exceed established thresholds.	Market Data Operations / Technology